

MÓDULO M4

SEGURIDAD Y CUMPLIMIENTO (DOMINIO 2)

MÓDULO M4

Sesión 4.1: Modelo de responsabilidad compartida



SEGURIDAD «DE» LA NUBE VS SEGURIDAD «EN» LA NUBE



- **Responsabilidad de AWS: Seguridad de la nube;** infraestructura global, hardware, hipervisores, redes troncales.
- **Responsabilidad del cliente: Seguridad en la nube;** datos del cliente, cifrado, firewalls, identidades, parches del SO en EC2.
- **Factor del modelo de servicio:** En servicios más abstractos (PaaS/SaaS), **AWS asume más capas operativas** (ej.: en RDS, AWS gestiona parches del motor en el modelo administrado).

SEGURIDAD «DE» LA NUBE VS SEGURIDAD «EN» LA NUBE



MÓDULO M4

Sesión 4.2: Identity and Access Management (IAM) - Identidad y Accesos



USUARIOS, GRUPOS, ROLES Y POLÍTICAS



- **Usuarios:** Personas o apps con credenciales de **largo plazo** (contraseña o access keys).
- **Grupos:** Colección de usuarios; permite asignar **permisos a muchos a la vez**.



USUARIOS, GRUPOS, ROLES Y POLÍTICAS



- **Roles:** Credenciales temporales asumibles; **para servicios** (ej.: EC2 → S3) o **identidades federadas**.
- **Políticas:** Documentos **JSON** que **permiten** o **deniegan acciones**.
- **MFA (Multi-Factor Authentication):** Segunda capa crítica; **obligatorio en el usuario raíz** (Root user) y recomendable en todos los usuarios.



USUARIOS, GRUPOS, ROLES Y POLÍTICAS

- **AWS IAM Identity Center - Antes AWS Single Sign-On (SSO):** Permite que los usuarios inicien sesión una sola vez y **accedan a múltiples cuentas AWS** (típicamente en **Organizations**) y a **aplicaciones SaaS externas**. Integrable con proveedores de identidad corporativos (Microsoft Entra ID, Okta, etc.).



Para CLF-C02:

«una identidad → muchas cuentas» → IAM Identity Center

«una identidad → una cuenta AWS» → IAM.

- **AWS Directory Service:** Directorio gestionado **compatible con Microsoft Active Directory** para cargas que requieren joins de dominio (Windows, aplicaciones heredadas).
- **Amazon Cognito:** Nos permite **gestionar identidad** para **usuarios finales de una app** (móvil/web). Registro, inicio de sesión, federación con Google/Facebook/Apple. No confundir con IAM Identity Center (para empleados de la organización).



MÉTODOS DE ACCESO A AWS — TRES VÍAS



	Método	Qué es	Credencial	Keyword examen
	AWS Management Console (Consola de administración)	Interfaz web gráfica — accedes desde el navegador a todos los servicios AWS	Usuario IAM + contraseña (+ MFA)	"browser", "console access", "graphical interface"
	AWS CLI (Command Line Interface)	Herramienta de línea de comandos para automatizar y scripting desde terminal	Access Key ID + Secret Access Key	"command line", "terminal", "automate", "programmatic access"
	AWS SDK (Software Development Kit)	Bibliotecas para lenguajes (Python, Java, Node.js, etc.) que llaman a la API de AWS desde código	Access Key ID + Secret Access Key	"application", "API calls", "code"

💡 Keywords del examen: "AWS Management Console / browser", "CLI / Access Keys", "SDK / programmatic".



Jemjaf

Demo — Módulo 4

DEMO — MÓDULO 4



Campo	Descripción rápida
Nombre	El principio de menor privilegio (Least privilege)
Objetivo	Mostrar Access Denied hasta asociar una política IAM
Opción	Cuenta AWS propia (Free Tier) o SandBox
Servicios	AWS IAM
Tiempo	~8 minutos
Costos	0 USD
Limpieza	Eliminar grupo, usuario y desasociar políticas al terminar



PASOS (HANDS-ON)



Paso 1: Entra a **IAM** (buscador superior: IAM).



Paso 2: En el menú izquierdo, abre **Usuarios** y haz clic en **Agregar usuarios**.



Paso 3: En **User name**, escribe **lp-test**. Permisos, selecciona **Agregar usuario a un grupo** y haz clic en **Crear grupo**.



Paso 4: Crea el grupo **lp-no-permissions** sin adjuntar políticas (deja la sección de políticas vacía) y finaliza con **Crear usuario**.



Paso 5: En la pantalla final de creación, entra a tu usuario **lp-test** y ve a la pestaña **Credenciales de seguridad**.



Paso 6: En **Claves de acceso**, haz clic en **Crear clave de acceso**. Elige el caso de uso que aplique (p. ej. Command Line Interface (CLI)) y **crea la key**. Descarga el **.csv** o **copia el Access key y Secret access key**.



PASOS (HANDS-ON)

-  **Paso 7:** Abre una ventana incógnita. **Inicia sesión** en la **Consola de administración de AWS** con esas credenciales (si usas IAM sign-in URL, pégala desde el panel de IAM).
-  **Paso 8 :** En la consola, busca y entra a **S3**. Intenta abrir **Buckets**. Debes ver **Acceso denegado** (o un error equivalente).
-  **Paso 9 :** Regresa a **IAM** (en tu sesión admin). Ve a **Usuarios**, entra a **lp-test** y haz clic en **Agregar permisos**.
-  **Paso 10 :** Selecciona **Adjuntar políticas directamente**. Busca **AmazonS3ReadOnlyAccess**, selecciónala y guarda con **Añadir Permisos**.
-  **Paso 11 :** Vuelve a tu sesión del usuario **lp-test**, recarga a **S3** y entra a **Buckets**. Ahora deberías poder ver los **buckets** (solo lectura).



Nota: el objetivo es que veamos el flujo real: usuario sin permisos → error → permiso mínimo necesario.



Limpieza: En **IAM**, elimina el usuario **lp-test** y luego elimina el grupo **lp-no-permissions**. Si creaste access keys, asegúrate de que queden eliminadas al borrar el usuario.



MÓDULO M4

Sesión 4.3: Banco de práctica



PREGUNTAS EN ESPAÑOL



Jemjaf

PREGUNTA 1



Según el **modelo de responsabilidad compartida**, ¿qué es exclusivo del cliente al usar **EC2 (IaaS)**?

- A) Firmware de enrutadores físicos
- B) Protección de la infraestructura física
- C) Parches del SO Linux de la instancia
- D) Retiro seguro de discos físicos defectuosos



PREGUNTA 1



Según el **modelo de responsabilidad compartida**, ¿qué es exclusivo del cliente al usar **EC2** (IaaS)?

✅ Respuesta correcta: C

💡 En AWS, el cliente es responsable de administrar y actualizar el sistema operativo de sus instancias EC2.



PREGUNTA 2



Una app en **EC2** debe **acceder a S3** sin contraseñas permanentes en el código.
¿Qué **entidad IAM** usar?

- A) IAM User
- B) IAM Group
- C) IAM Role
- D) Root User



PREGUNTA 2



Una app en **EC2** debe **acceder a S3 sin contraseñas permanentes en el código**.
¿Qué **entidad IAM** usar?

✓ Respuesta correcta: C

💡 Un IAM Role permite otorgar permisos temporales a EC2 sin almacenar |
credenciales en el código.



PREGUNTA 3



¿Qué **método exige dos o más factores** para la consola y aumenta la seguridad?

?

- A) SSO
- B) MFA
- C) Security Groups
- D) Access Keys



PREGUNTA 3



¿Qué **método exige dos o más factores** para la consola y aumenta la seguridad?



✓ Respuesta correcta: B

💡 MFA agrega una capa extra de seguridad al requerir más de un método de autenticación para iniciar sesión.



PREGUNTA 4

Mejores prácticas para el **Root User**: (Seleccione **DOS.**)

?

- A) Usarlo para tareas diarias (crear EC2)
- B) Habilitar MFA
- C) Compartir credenciales con el equipo
- D) Eliminar access keys del root
- E) Guardar las access keys del root sin rotación en un repositorio git privado

PREGUNTA 4



Mejores prácticas para el **Root User**: (Seleccione **DOS**.)



✓ Respuesta correcta: B y D

💡 El usuario root debe protegerse con MFA y evitar el uso de access keys para reducir riesgos de acceso no autorizado.



PREGUNTA 5



Otorgar **solo lectura** de S3 idéntica a **20 empleados**. ¿Enfoque **más eficiente**?

?

- A) Política en cada usuario
- B) Cambiar código fuente
- C) Grupo IAM con la política; añadir los 20 usuarios
- D) Un usuario y contraseña compartida



PREGUNTA 5



Otorgar **solo lectura** de S3 idéntica a **20 empleados**. ¿Enfoque **más eficiente**?

?

✅ Respuesta correcta: C

💡 Un grupo IAM simplifica la administración aplicando la misma política a múltiples usuarios de forma centralizada.



PRACTICE QUESTIONS IN ENGLISH

QUESTION 1

Under the **AWS Shared Responsibility Model**, *what is the customer's responsibility when **using Amazon EC2 (IaaS)***?



- A) Firmware for physical routers
- B) Protection of the physical infrastructure
- C) Patching the instance's Linux operating system
- D) Secure disposal of failed physical disks

QUESTION 1

Under the **AWS Shared Responsibility Model**, *what is the customer's responsibility when **using Amazon EC2 (IaaS)**?*

?

✓ Correct answer: C

💡 In AWS, the customer is responsible for managing and patching the operating system of their EC2 instances.

QUESTION 2

An application running on **EC2** must access **S3** without permanent passwords in the **code**. Which **IAM entity** should be used?



- A) IAM User
- B) IAM Group
- C) IAM Role
- D) Root User

QUESTION 2



An application running on **EC2 must access S3 without permanent passwords in the code**. Which **IAM entity** should be used?

✓ Correct answer: C

💡 An IAM Role provides temporary permissions to EC2 without storing credentials in the application code.

QUESTION 3

Which method requires **two or more factors** to sign in to the **AWS Management Console** and **increases security**?

?

- A) SSO
- B) MFA
- C) Security Groups
- D) Access Keys

QUESTION 3

Which method requires **two or more factors** to sign in to the **AWS Management Console** and **increases security**?

?

✓ Correct answer: B

💡 MFA adds an extra layer of security by requiring more than one authentication factor to sign in.

QUESTION 4

Root User best practices: (SELECT **TWO**.)

?

- A) Use it for daily tasks (launch EC2)
- B) Enable MFA
- C) Share credentials with the team
- D) Delete the root access keys
- E) Store the root access keys without rotation in a private git repository

QUESTION 4

Root User best practices: (SELECT **TWO**.)

?

✓ Correct answer: B and D

💡 The root user should be protected with MFA and should not use access keys to reduce the risk of unauthorized access.

QUESTION 5



You need to grant **identical S3 read-only access** to **20 employees**. *What is the **most efficient** approach?*

- A) Attach the policy to each user
- B) Change source code
- C) Create an IAM Group with the policy and add the 20 users
- D) Use one shared username and password



QUESTION 5



You need to grant **identical S3 read-only access** to **20 employees**. *What is the **most efficient** approach?*

✓ Correct answer: C

💡 An IAM Group simplifies management by applying the same policy to multiple users centrally.